Lab 1: Practical Vulnerability Assessment

Student Name: Faith Mathapelo Letsoara

Registration number: C11/26/CGRC/17582

Cohort /Batch: Cohort 11

Instructor Name: Steve Wamala Gamba

Date of Submission: 25/10/2026

Executive Summary

As part of this lab, a vulnerability assessment was conducted on the Metasploitable 2 virtual machine to identify potential security weaknesses. The assessment was performed using Nmap, Nikto, and Nuclei.
During the assessment, several vulnerabilities and security misconfigurations were identified. These included weak FTP credentials, anonymous FTP access, outdated software versions, missing HTTP security headers, and a critical FTP-related vulnerability. Multiple network services were also found to be exposed.
If these vulnerabilities were present in a production environment, they could increase the risk of unauthorized access, information disclosure, and system compromise. Based on the findings, several remediation recommendations are provided to improve the overall security posture of the system.

Introduction
The purpose of this assessment was to identify vulnerabilities on a target system and evaluate the potential risks they may pose. Vulnerability assessments are an important part of maintaining a secure environment because they help organizations identify weaknesses before they can be exploited by attackers.
For this lab, the target system was Metasploitable 2, a deliberately vulnerable Linux machine used for security training and testing.

2 Scope

Item	Description
Target System	Metasploitable2
IP Address	192.168.56.101
Assessment Type	Internal Vulnerability Assessment
Tools used	Nmap, Nikto, Nuclei

3. Methodology
To complete the assessment, I used three different tools.

Nmap
Nmap was used to identify open ports and running services on the target system. This helped determine which services were exposed and required further investigation.

Nikto
Nikto was used to assess the web server and identify potential web-related vulnerabilities, insecure configurations, and outdated components.

Nuclei
Nuclei was used to perform vulnerability scanning and identify known vulnerabilities, weak credentials, outdated software, and missing security controls.

4. Evidence and Scan Results

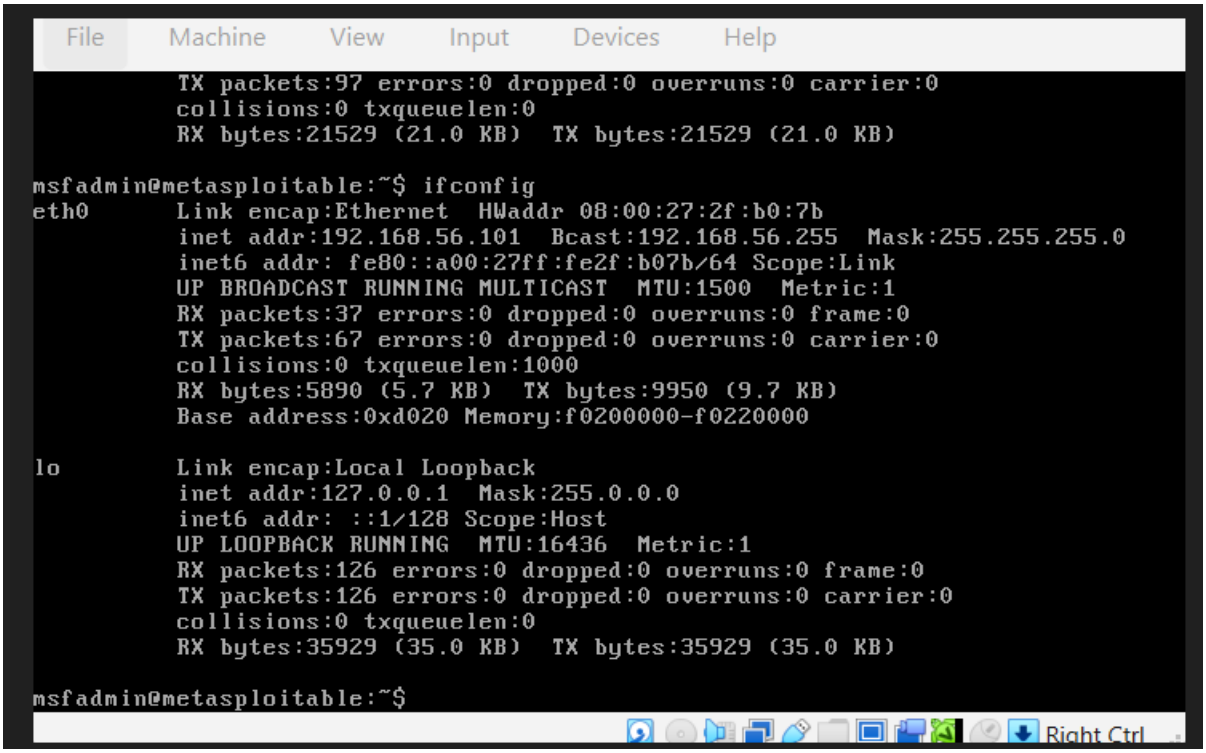
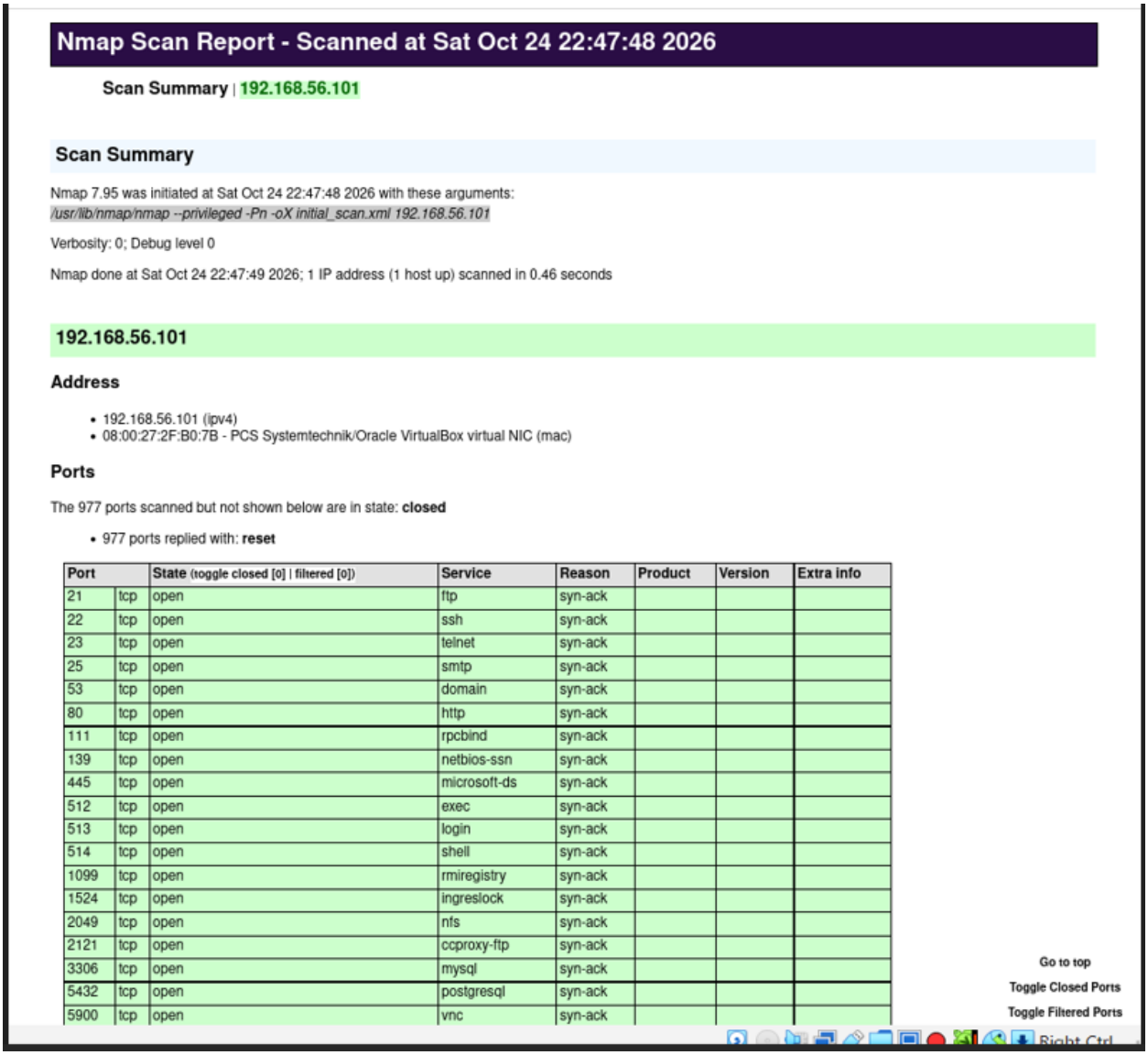


Figure 1: Target Verification

Verification of the target system IP address (192.168.56.101).

Before beginning the assessment, the IP address of the Metasploitable virtual machine was verified to ensure all scans were performed against the correct target.



Nmap Scan Report - Scanned at Sat Oct 24 22:47:48 2026

Scan Summary | 192.168.56.101

Scan Summary

Nmap 7.95 was initiated at Sat Oct 24 22:47:48 2026 with these arguments:
/usr/lib/nmap/nmap --privileged -Pn -oX initial_scan.xml 192.168.56.101

Verbosity: 0; Debug level 0

Nmap done at Sat Oct 24 22:47:49 2026; 1 IP address (1 host up) scanned in 0.46 seconds

192.168.56.101

Address

- 192.168.56.101 (ipv4)
- 08:00:27:2F:B0:7B - PCS Systemtechnik/Oracle VirtualBox virtual NIC (mac)

Ports

The 977 ports scanned but not shown below are in state: **closed**

- 977 ports replied with: **reset**

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack			
22	tcp	open	ssh	syn-ack			
23	tcp	open	telnet	syn-ack			
25	tcp	open	smtp	syn-ack			
53	tcp	open	domain	syn-ack			
80	tcp	open	http	syn-ack			
111	tcp	open	rpcbind	syn-ack			
139	tcp	open	netbios-ssn	syn-ack			
445	tcp	open	microsoft-ds	syn-ack			
512	tcp	open	exec	syn-ack			
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack			
1099	tcp	open	rmiregistry	syn-ack			
1524	tcp	open	ingreslock	syn-ack			
2049	tcp	open	nfs	syn-ack			
2121	tcp	open	ccproxy-ftp	syn-ack			
3306	tcp	open	mysql	syn-ack			
5432	tcp	open	postgresql	syn-ack			
5900	tcp	open	vnc	syn-ack			

Go to top
Toggle Closed Ports
Toggle Filtered Ports

Figure 2: Nmap HTML Report

Results of the Nmap scan showing open ports and services.

The Nmap scan revealed several open ports and exposed services including FTP, SSH, Telnet, SMTP, HTTP, MySQL, PostgreSQL, and VNC. The presence of numerous exposed services increases the attack surface and provides additional opportunities for exploitation if vulnerabilities exist within those services

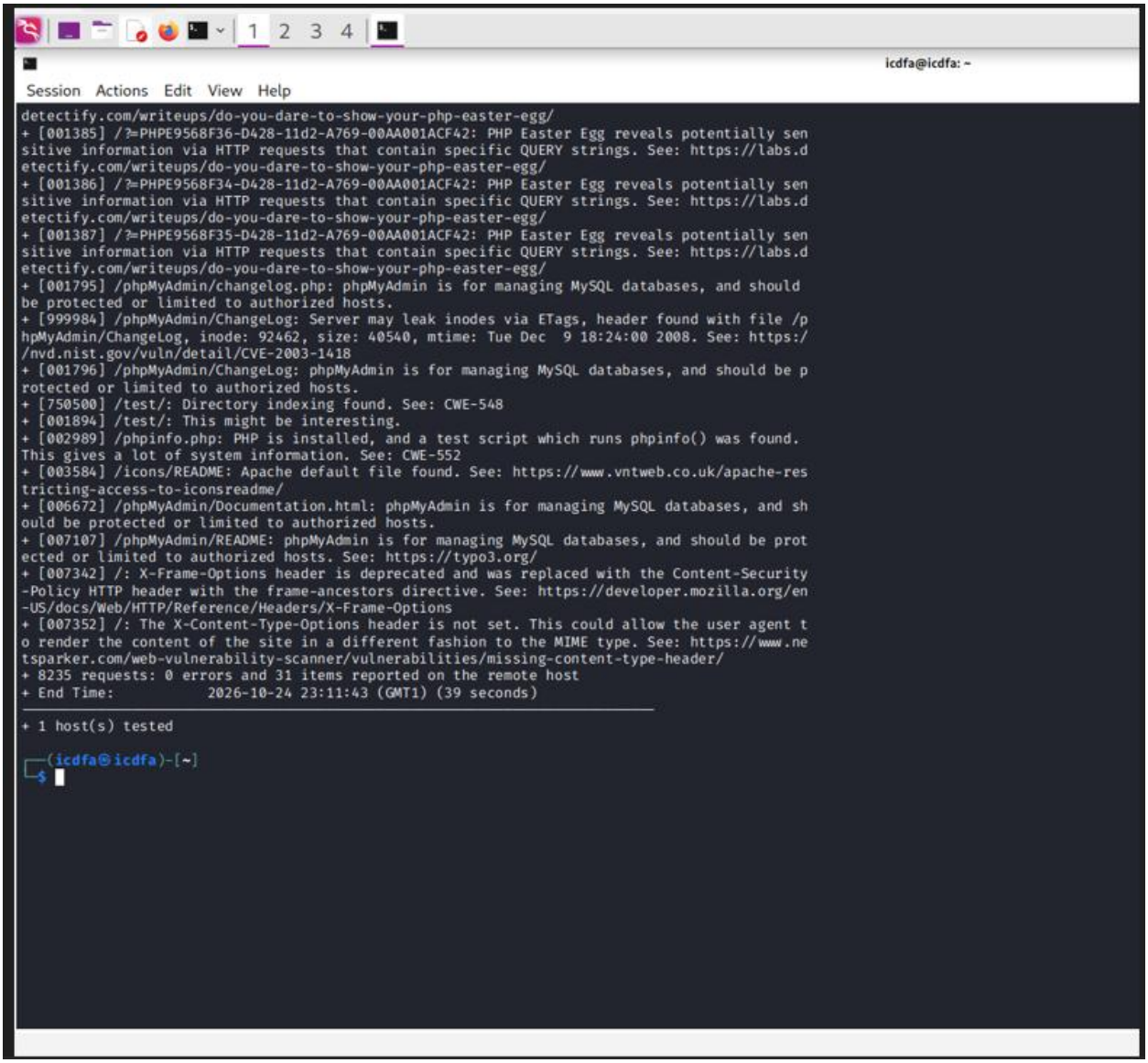


Figure 3: Nikto Scan Results

Nikto scan identifying web application vulnerabilities and configuration issues.
The Nikto assessment identified several web server findings including outdated components, information disclosure issues, and missing security protections. These findings indicate weaknesses in the web server configuration that could be leveraged by an attacker.

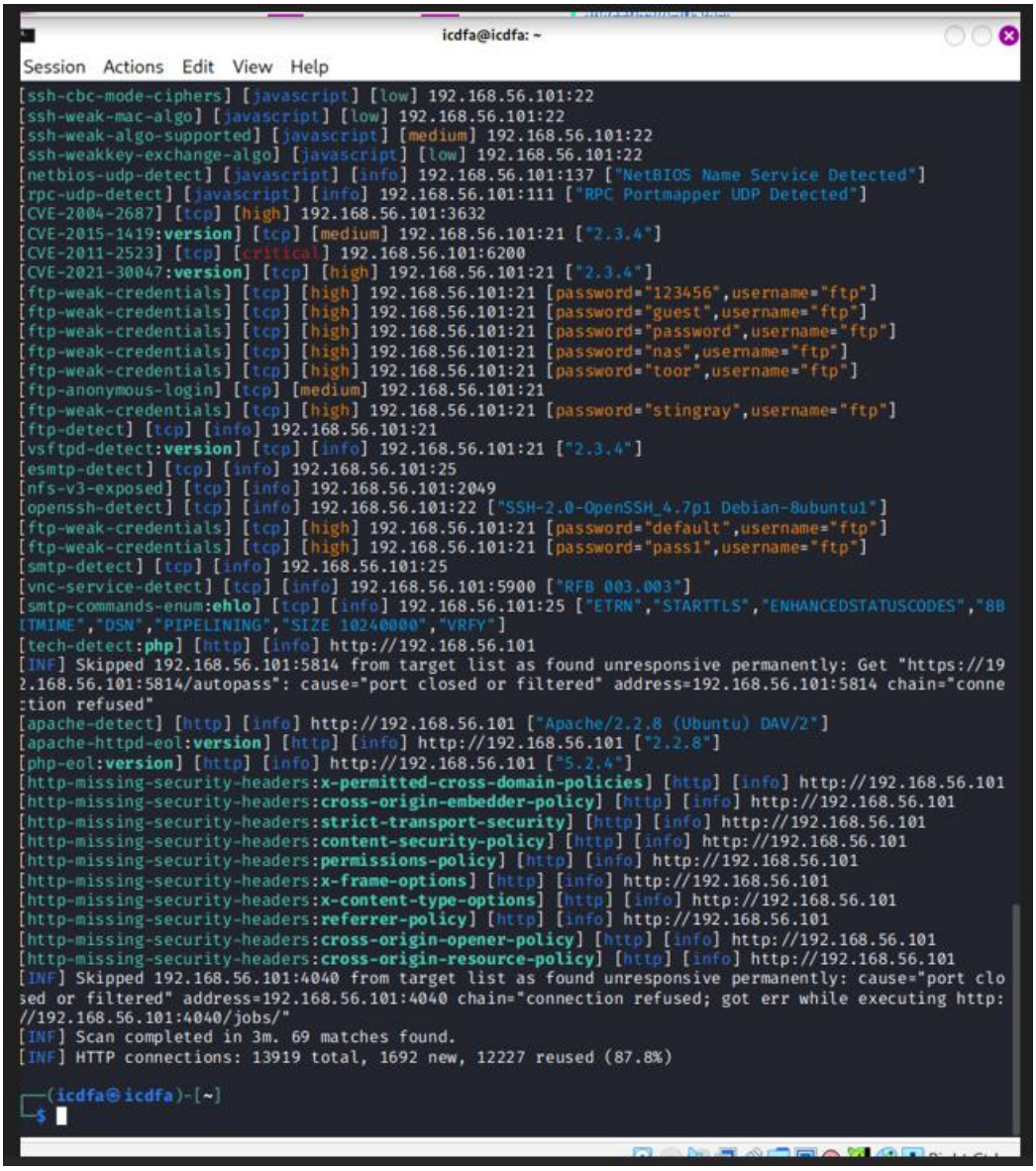


Figure 4: Nuclei Vulnerability Scan Results

The Nuclei scan detected a total of 69 findings. These findings included weak FTP credentials, anonymous FTP access, outdated software versions, missing HTTP security headers, exposed services, and a critical FTP-related vulnerability. The results highlight several areas where security controls could be improved.

.

5. Key Findings

The most significant findings identified during the assessment are summarized below:

1. Weak FTP Credentials
Multiple weak credentials were identified for the FTP service. Weak passwords increase the likelihood of unauthorized access.

2. Anonymous FTP Access
Anonymous access was enabled on the FTP service, allowing access without proper authentication.

3. Outdated Apache Version
The web server was running Apache 2.2.8, which is outdated and may contain known vulnerabilities.

4. Outdated PHP Version
PHP version 5.2.4 was detected. This version is no longer supported and may expose the system to security risks.

5. Weak SSH Configuration
Weak SSH algorithms were identified. Older cryptographic algorithms may make secure communications more vulnerable to attack.

6. Missing HTTP Security Headers
Several important security headers were missing, increasing exposure to certain web-based attacks.

7. Critical FTP Vulnerability
A critical vulnerability associated with the FTP service was identified and represents one of the highest-risk findings discovered during the assessment.

6. Risk Assessment Table

Finding	Affected Service	CVE/Reference	Risk Level	Compliance Violation	Business Impact
Weak FTP Credentials	FTP	N/A	High	CIS Control 5	Unauthorized access to systems and data
Anonymous FTP Access	FTP	N/A	Medium	CIS Control 5	Information disclosure
vsFTPd Backdoor vulnerability	FTP	CVE-2011-2523	High	CIS Control 7	Potential full System compromise

Weak SSH Algorithms	SSH	Nuclei Finding	Medium	NIST PR.DS-2	Reduced strength of secure communications
Outdated Apache Version	HTTP	Apache 2.2.8	High	CIS Control 7	Exploitation of known vulnerabilities
Outdated PHP Version	HTTP/PHP	PHP 5.2.4	High	CIS Control 7	Increased risk of code execution attacks
Missing HTTP Security Headers	Web Server	Nikto/Nuclei Finding	Medium	PCI DSS Req.6	Increased exposure to web-based attacks
Exposed Network Services	RPC,NFS,VNC	Nmap Findings	Medium	NIST PR.AC	Larger attack surface

7 Recommendations

Based on the findings, the following actions are recommended:

- Remove weak and default passwords from all services.
- Disable anonymous FTP access.
- Upgrade Apache and PHP to supported versions.
- Apply security patches on a regular basis.
- Disable unnecessary network services.
- Strengthen SSH configurations by removing weak algorithms.
- Implement missing HTTP security headers.
- Conduct regular vulnerability assessments to identify new risks.

8. Conclusion

This assessment successfully identified several vulnerabilities and security weaknesses on the Metasploitable system. The results demonstrate the importance of regular vulnerability assessments, strong password policies, secure configurations, and timely patch management.

Addressing the identified findings would significantly improve the system's overall security and reduce the likelihood of successful attacks.